

Manual 44 — Implementación controlada de NIST SSDF / SP 800-218

****Línea base controlada:**** NIST SP 800-218 SSDF v1.1 final y SP 800-218A final como perfil comunitario de IA. SP 800-218 Rev.1 / SSDF v1.2 permanece en vigilancia de cambios salvo reverificación como final al publicar.

Chapter 01 — Jerarquía de fuentes y versiones

Mantener estado final/borrador, fuentes autoritativas, fechas, vigilancia de cambios, responsables y evidencia.

Chapter 02 — Alcance de SSDF

Definir productos, servicios, código, infraestructura, canalizaciones, proveedores, componentes de IA y etapas del ciclo de vida.

Chapter 03 — Preparar la organización

Establecer políticas, roles, recursos, capacitación, herramientas, entornos, métodos de riesgo y gobierno.

Chapter 04 — Proteger el software

Proteger código fuente, repositorios, compilaciones, credenciales, artefactos, configuraciones y entornos.

Chapter 05 — Producir software bien protegido

Aplicar diseño, implementación, revisión, análisis, pruebas, dependencias, configuración e integridad de liberación.

Chapter 06 — Responder a vulnerabilidades

Operar recepción, triaje, análisis, remediación, divulgación, coordinación, verificación y lecciones aprendidas.

Chapter 07 — Gobierno y roles

Asignar responsables en producto, ingeniería, seguridad, operaciones, compras, legal, privacidad, riesgo y dirección.

Chapter 08 — Diseño seguro

Definir requisitos, límites de confianza, valores seguros por defecto, protección de datos y privilegios.

Chapter 09 — Modelado de amenazas

Identificar activos, adversarios, rutas de ataque, casos de abuso, dependencias, mitigaciones y riesgo residual.

Chapter 10 — Revisión de arquitectura

Revisar identidad, flujos, aislamiento, criptografía, resiliencia, interfaces y supuestos de despliegue.

Chapter 11 — Control de código fuente

Proteger ramas, commits, revisiones, identidades, permisos, configuración, procedencia e historial.

Chapter 12 — Integridad de compilación

Asegurar servicios, runners, compiladores, dependencias, configuración, aislamiento, registros y artefactos.

Chapter 13 — Gobierno de dependencias

Inventariar dependencias directas/transitivas y evaluar procedencia, vulnerabilidades, licencias y mantenimiento.

Chapter 14 — SBOM y procedencia

Generar y proteger SBOM, metadatos de origen, atestaciones, relaciones de componentes y retención.

Chapter 15 — Secretos

Evitar secretos codificados; controlar creación, almacenamiento, entrega, escaneo, rotación y revocación.

Chapter 16 — Codificación segura

Aplicar reglas por lenguaje/plataforma para entradas, salidas, errores, memoria, autenticación y autorización.

Chapter 17 — Revisión de código y análisis estático

Usar revisión por pares y análisis automatizado, controlando hallazgos, excepciones y remediación.

Chapter 18 — Pruebas dinámicas y de seguridad

Usar pruebas unitarias, integración, fuzzing, penetración, abuso, API y configuración según riesgo.

Chapter 19 — Controles CI/CD

Proteger definiciones, identidades, aprobaciones, entornos, artefactos, secretos, registros y despliegues.

Chapter 20 — Separación de entornos

Separar desarrollo, prueba, staging, producción, firma, datos sensibles y actividades de alta confianza.

Chapter 21 — Integridad, firma y atestación de liberación

Verificar fuente aprobada, pruebas, dependencias, procedencia, firmas, checksums y autorización.

Chapter 22 — Recepción de vulnerabilidades

Mantener canales internos/externos, divulgación coordinada, deduplicación, severidad y preservación de evidencia.

Chapter 23 — Remediación y priorización

Priorizar por explotabilidad, exposición, impacto, alcance, controles compensatorios y explotación activa.

Chapter 24 — Aseguramiento de proveedores

Evaluar desarrollo, servicios, componentes, dependencias de compilación, incidentes y acciones correctivas.

Chapter 25 — Adquisición de software

Definir requisitos de desarrollo seguro y evaluar evidencia, vulnerabilidades, procedencia, mantenimiento y salida.

Chapter 26 — Retroalimentación de incidentes

Incorporar incidentes, vulnerabilidades, red-team y postmortems en requisitos, diseño, capacitación y controles.

Chapter 27 — Controles del perfil de desarrollo de IA

Aplicar SP 800-218A cuando corresponda a modelos, código, datos, procedencia, evaluación y despliegue.

Chapter 28 — Límites de superposiciones federales y contractuales

Mantener SSDF separado de mandatos de agencia, cláusulas, contratos, normas sectoriales y requisitos internos.

Chapter 29 — Evidencia y métricas

Medir adopción, cobertura, antigüedad de vulnerabilidades, revisiones, pruebas, dependencias y excepciones.

Chapter 30 — Excepciones y mejora continua

Documentar excepciones, aceptación de riesgo, controles compensatorios, caducidad y acciones correctivas.

Chapter 31 — Localización y procedencia

Congelar candidatos EN/es-419/pt-BR y vincular identidades DOCX/PDF a SHA-256 con evidencia de QA.

Chapter 32 — Vigilancia de borradores y reverificación final

Antes de publicar, confirmar estado NIST, publicación del Manual 43, identidad exacta y QA limpio.